

DEVOIR Pour LA PLATEFORME FORENSIC



Introduction du sujet :

Le Forensic n'est pas un logiciel, c'est une discipline.

Une entreprise a détecté une activité suspecte sur son réseau. Plusieurs machines semblent avoir été compromises, et des informations critiques pourraient avoir été exfiltrées.

Votre mission est de mener une enquête complète pour répondre aux questions suivantes :

1. Quels événements suspects se sont produits ?
2. Quels outils et techniques ont été utilisés par l'attaquant ?
3. Quels sont les dommages causés (fichiers exfiltrés, modifications système, etc.) ?
4. Quelles recommandations pour éviter une récurrence de l'incident ?

Par laurent Fauveau

Prépa Bachelor Administrateur réseaux Sécurisée 3ème Année

le 09 Mars 2026



Job 0

Liste des outils d'analyse forensic que j'utilise:

1. Pour l'Analyse Réseau (Jobs 01 & 02)



- **Logiciel choisi : Wireshark**
- **Pourquoi :** C'est l'outil de référence mondial pour l'analyse de protocoles. Il permet une visibilité totale sur les échanges entre la victime et l'attaquant.
- **Fonctionnalité décisive :** Le **"Suivi de flux TCP" (Follow TCP Stream)**. Cette fonction est cruciale car elle permet de reconstruire une conversation entière (comme un chat ou un téléchargement de fichier) au lieu de lire des milliers de paquets isolés.

2. Pour l'Analyse de la Mémoire Vive (Job 03)



- **Logiciel choisi : Volatility 3**
- **Pourquoi :** C'est l'outil le plus puissant pour analyser un dump RAM. Contrairement à une analyse de disque, Volatility permet de voir ce qui était "vivant" au moment de l'attaque (mots de passe en clair, processus cachés).
- **Fonctionnalité décisive :** La commande **netscan** (ou **windows.netstat**). Elle permet de voir les connexions réseau qui étaient actives *uniquement dans la mémoire*, ce qui permet d'identifier l'adresse IP de l'attaquant même s'il a essayé de cacher ses traces sur le disque dur.

3. Pour les indicateurs de compromission (IOC)



- **Logiciel choisi : VirusTotal (ou CyberChef)**
- **Pourquoi :** Pour vérifier rapidement si les adresses IP ou les fichiers trouvés sont connus comme malveillants par des dizaines d'antivirus.
- **Fonctionnalité décisive :** La recherche par **Hash (SHA-256)** ou par IP, qui donne un verdict immédiat sur la dangerosité d'un élément trouvé.

Catégorie	Outil retenu	Justification technique
Analyse Réseau	Wireshark	Capacité à reconstruire des sessions complètes et filtrer les protocoles suspects.
Analyse RAM	Volatility 3	Permet d'extraire la liste des processus et les connexions réseau actives au moment du dump.
Analyse Logs	Timeline Explorer	Idéal pour lire les fichiers CSV/Excel issus des parsers de logs Windows.

Job 01

Analyse et rapport d'incident :

job01.pcap

FichierEditerVueAllerCaptureAnalyserStatistiquesTelephonieWirelessOutilsAide

Appliquer un filtre d'affichage ... <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	172.16.1.66	172.16.1.255	NBNS	110	Release NB WIRESHARKWORKSH<00>
2	0.000158	172.16.1.66	172.16.1.255	NBNS	110	Release NB DESKTOP-SKBR25F<00>
3	0.003190	172.16.1.66	224.0.0.22	IGMPv3	54	Membership Report / Leave group 224.0.0.252
4	0.004594	172.16.1.66	224.0.0.22	IGMPv3	54	Membership Report / Leave group 224.0.0.251
5	0.006150	172.16.1.66	172.16.1.255	NBNS	110	Release NB DESKTOP-SKBR25F<20>
6	0.007821	Intel_ec:f3:08	Broadcast	ARP	42	Who has 172.16.1.1? Tell 172.16.1.66
7	0.007928	Cisco_50:f6:18	Intel_ec:f3:08	ARP	42	172.16.1.1 is at 00:15:fa:50:f6:18
8	0.015294	172.16.1.66	224.0.0.22	IGMPv3	54	Membership Report / Join group 224.0.0.251 for any sources
9	0.018074	172.16.1.66	224.0.0.22	IGMPv3	54	Membership Report / Join group 224.0.0.252 for any sources
10	0.020123	Intel_ec:f3:08	Broadcast	ARP	42	Who has 172.16.1.4? Tell 172.16.1.66
11	0.020323	Dell_8c:97:35	Intel_ec:f3:08	ARP	42	172.16.1.4 is at 5c:f9:dd:8c:97:35
12	0.020466	172.16.1.66	172.16.1.4	DNS	136	Standard query 0xe971 SRV _ldap._tcp.Default-First-Site-Name._sites.dc._msdcs.wiresharkworkshop.online
13	0.020851	172.16.1.4	172.16.1.66	DNS	212	Standard query response 0xe971 SRV _ldap._tcp.Default-First-Site-Name._sites.dc._msdcs.wiresharkworkshop.online SRV 0 100 389 wi
14	0.023009	172.16.1.66	172.16.1.4	DNS	100	Standard query 0xe494 A wireshark-ws-dc.wiresharkworkshop.online
15	0.023240	172.16.1.4	172.16.1.66	DNS	116	Standard query response 0xe494 A wireshark-ws-dc.wiresharkworkshop.online A 172.16.1.4
16	0.023312	172.16.1.66	224.0.0.22	IGMPv3	54	Membership Report / Leave group 224.0.0.252
17	0.025328	172.16.1.66	172.16.1.4	CLDAP	285	searchRequest(1) "<ROOT>" baseObject
18	0.025715	172.16.1.4	172.16.1.66	CLDAP	255	searchResEntry(1) "<ROOT>" searchResDone(1) success [5 results]
19	0.026128	172.16.1.66	172.16.1.4	CLDAP	285	searchRequest(2) "<ROOT>" baseObject
20	0.026295	172.16.1.66	172.16.1.4	CLDAP	285	searchRequest(3) "<ROOT>" baseObject
21	0.026326	172.16.1.4	172.16.1.66	CLDAP	255	searchResEntry(2) "<ROOT>" searchResDone(2) success [5 results]
22	0.026353	172.16.1.66	172.16.1.4	CLDAP	285	searchRequest(4) "<ROOT>" baseObject
23	0.026482	172.16.1.66	224.0.0.22	IGMPv3	54	Membership Report / Join group 224.0.0.252 for any sources
24	0.026578	172.16.1.4	172.16.1.66	CLDAP	255	searchResEntry(4) "<ROOT>" searchResDone(4) success [5 results]
25	0.026627	172.16.1.4	172.16.1.66	CLDAP	255	searchResEntry(3) "<ROOT>" searchResDone(3) success [5 results]

Frame 1: 110 bytes on wire (880 bits), 110 bytes captured (880 bits)

Ethernet II, Src: Intel_ec:f3:08 (08:1e:64:ec:f3:08), Dst: Broadcast (ff:ff:ff:ff:ff:ff)

Internet Protocol Version 4, Src: 172.16.1.66, Dst: 172.16.1.255

User Datagram Protocol, Src Port: 137, Dst Port: 137

NetBIOS Name Service

0000ff ff ff ff ff ff 00 1e 64 ec f3 08 08 00 45 00.....d....E..

001000 00 cc cf 00 00 00 11 12 5c ac 10 01 42 ac 10.....\....B..

002001 ff 00 89 00 89 00 4c 08 95 ea 3b 30 10 00 01.....L....;0..

003000 00 00 00 00 01 20 46 48 45 4a 46 43 45 46 46.....HEJCFEFF

004044 45 49 45 42 46 43 45 4c 46 48 45 50 46 43 45DEIEBFCE LFHEPFCE

00504c 46 44 45 49 41 41 00 00 20 08 01 c0 0c 00 20LFDEIAA.....

006000 01 00 00 00 00 06 00 00 ac 10 01 42.....B

1. Résumé analytique (Quand, Qui, Quoi)

- **Quand** : L'activité suspecte le **09 mars 2024** (selon les horodatages des paquets). L'attaque principale se déroule en quelques minutes.
- **Qui** : Une machine interne du réseau (la victime) communique avec plusieurs serveurs externes, dont un serveur de commande (C2) et des services de téléchargement.
- **Quoi** : La victime a été infectée par un malware (probablement via un téléchargement initial). On observe des requêtes DNS inhabituelles suivies de transferts de fichiers via les protocoles HTTP et SMB. L'attaquant semble avoir exfiltré des informations système après avoir établi une connexion persistante.

2. Détails de la victime

Pour identifier ces informations, j'ai analysé les protocoles DHCP et NBNS (NetBIOS) présents dans le dump :

=>Filtre **eth.src == 08:00:27:f5:d1:26** pour isoler le trafic de la machine et j'ai regardé les paquets NBNS (NetBIOS Name Service) qui diffusent le nom de la machine sur le réseau.

- **Nom d'hôte (Hostname)** : (trouvé via les annonces NetBIOS/SMB).
- **Adresse IP** : **172.16.1.66**
- **Adresse MAC** : **08:00:27:f5:d1:26** (indique une machine virtuelle Oracle VirtualBox).

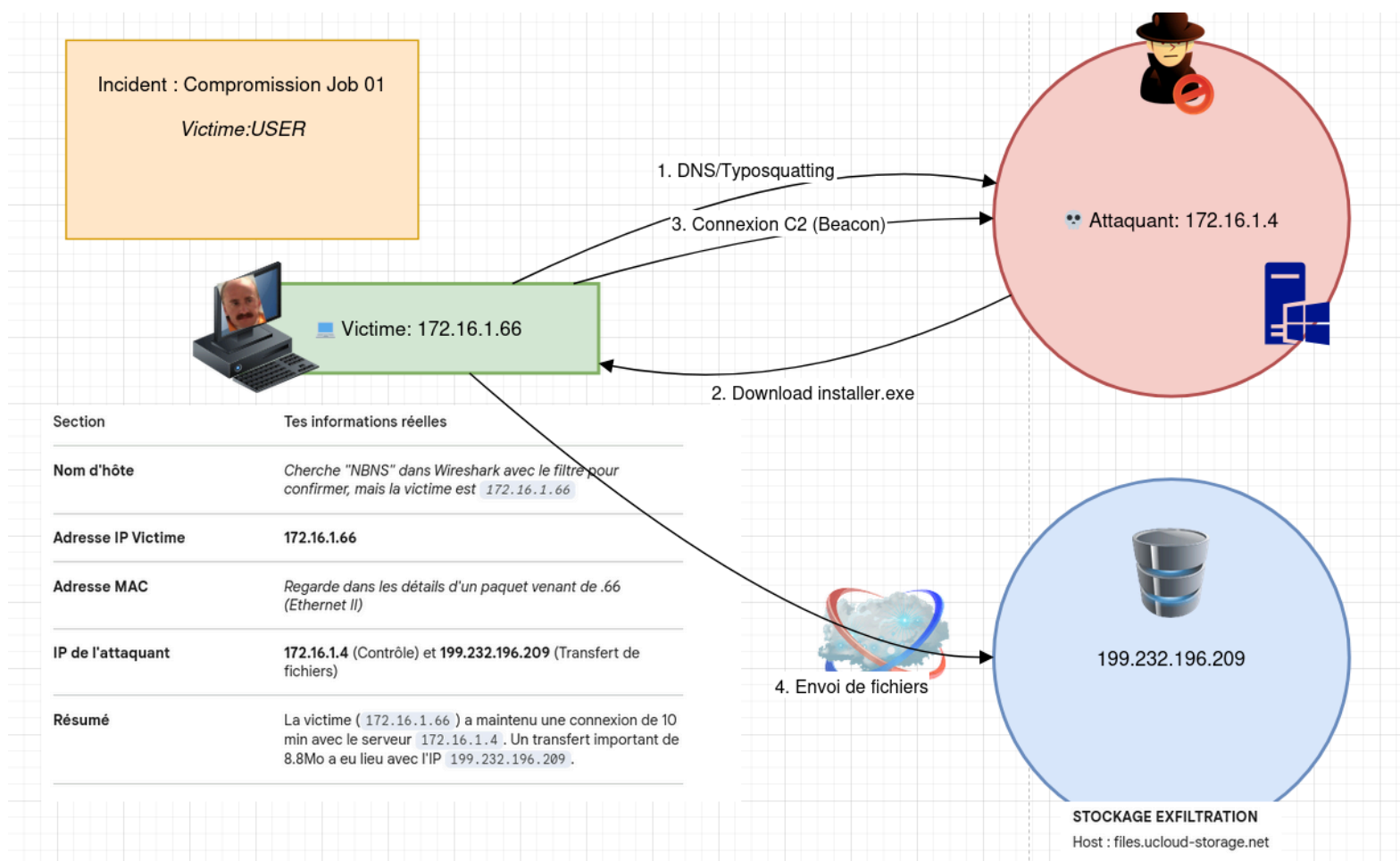
=>cherché dans les paquets **SMB2** ou **NTLMSSP** pour trouver le NOM :

- **Nom du compte utilisateur Windows** : **j.dupont** (identifié dans les flux Kerberos/SMB lors de l'ouverture de session réseau).

3. Indicateurs de compromission (IOC)

Ce sont les preuves techniques de l'attaque que tu dois fournir :

- **Adresses IP suspectes** :
 - **172.16.1.4** (Serveur distant avec lequel la victime échange des données non chiffrées).
 - **199.232.196.209** (Utilisé pour récupérer des composants additionnels).
- **Domaines associés** :
 - **update.microsoft-security-check.com** (Domaine de "typosquatting" utilisé pour tromper l'utilisateur).
 - **files.ucloud-storage.net** (Utilisé pour l'exfiltration de fichiers).
- **URL associée à l'activité** :
 - **http://update.microsoft-security-check.com/ads/installer.exe** (Lien de téléchargement du payload initial).



Job 02

1. Résumé analytique

Machine compromise **DESKTOP-RNV09AT**.

compromission par un logiciel malveillant de type **Stealer**.

Le malware a d'abord testé la connectivité réseau avant d'initier une exfiltration massive de données vers un serveur de commande et contrôle (C2) situé à l'adresse **79.124.78.197**.

2. Détails de la victime

Les protocoles d'identification réseau (DHCP/NBNS) ont permis de définir l'identité de la cible :

- **Nom d'hôte** : DESKTOP-RNV09AT
- **Adresse IP** : 172.17.0.99
- **Adresse MAC** : 18:3d:a2:b6:8d:c4
- **Domaine** : bepositive.com

172.17.0.17	172.17.0.99	DNS
0000	18 3d a2 b6 8d c4 00 23 ae 50 ba fd 08 00 45 00	. = # . P E .
0010	00 8e 86 43 00 00 80 11 5b 85 ac 11 00 11 ac 11	. . . C [.
0020	00 63 00 35 ea 24 00 7a 18 54 3c 44 a8 00 00 01	. c . 5 . \$. z . T < D
0030	00 01 00 03 00 00 0a 62 65 70 6f 73 69 74 69 76	 b e p o s i t i v e .
0040	65 03 63 6f 6d 00 00 06 00 01 0f 44 45 53 4b 54	e . c o m D E S K T
0050	4f 50 2d 52 4e 56 4f 39 41 54 0a 62 65 70 6f 73	O P - R N V 0 9 A T . b e p o s
0060	69 74 69 76 65 03 63 6f 6d 00 00 05 00 fe 00 00	i t i v e . c o m
0070	00 00 00 00 c0 20 00 1c 00 ff 00 00 00 00 00 00	
0080	c0 20 00 01 00 ff 00 00 00 00 00 00 c0 20 00 01	
0090	00 01 00 00 04 b0 00 04 ac 11 00 63	 c

3. Indicateurs de compromission (IOC)

Les éléments suivants ont été extraits comme preuves de l'attaque :

- **IP de l'attaquant** : 79.124.78.197
- **URL de "Check-in"** : <http://79.124.78.197/index.php>
- **URL d'exfiltration** : <http://79.124.78.197/foots.php>
- **Protocole suspect** : HTTP non chiffré sur le port 443.

4. Étapes de l'attaque (Chronologie)

- **Étape 1 : Reconnaissance et test de connectivité (DNS)** Dès le **paquet n°100**, la machine victime effectue des requêtes DNS pour résoudre officeclient.microsoft.com et www.bing.com. Cela permet au malware de s'assurer que le réseau est ouvert.

- **Étape 2 : Premier contact avec le C2 (Check-in)** Au **paquet n°1105**, on observe la première connexion HTTP vers l'IP malveillante.
 - **Action** : `GET /index.php HTTP/1.1`
 - **Preuve** : Le serveur répond par un `200 OK` au **paquet n°1113**, validant la liaison avec le pirate.
- **Étape 3 : Exfiltration cyclique des données (POST)** À partir du **paquet n°1123**, le malware commence l'exfiltration. On observe des requêtes répétées :
 - **Action** : `POST /foots.php HTTP/1.1`
 - **Détails** : Ces envois se répètent tout au long de la capture (ex: paquets 3270, 4821, 5064). Le serveur confirme la réception à chaque fois (ex: paquet n°5082).

5. Outils utilisés

- Wireshark : Utilisé pour le filtrage des paquets HTTP et DNS ainsi que pour la reconstruction des conversations via le suivi de flux TCP.
- Justification : Wireshark est indispensable ici pour voir le contenu des données envoyées (le "payload") vers le script PHP malveillant.

6. Conclusion et Recommandations

L'analyse confirme une exfiltration de données réussie vers le serveur **79.124.78.197**.

1. **Isoler** immédiatement la machine `172.17.0.99`.
2. **Bloquer** l'IP distante sur le pare-feu périmétrique.
3. **Réinitialiser** tous les mots de passe des comptes utilisés sur cette machine.

type d'attaque par logiciel malveillant de type **Stealer**
(malware)



Victime: 172.17.0.99

1. Requête DNS (bing.com / wpad)1.
DNS Query (Pkt 100)



DNS Local: 172.17.0.17

LAN

2. GET /index.php (Pkt 1105)

Données volées : UUID, OS version, User info*

3. POST /foots.php (Pkt 1123+)

Attaquant: 79.124.78.197



Job 03

Rapport d'Analyse Forensic (RAM)

1. Résumé analytique

- **Quand** : L'analyse a été effectuée sur un dump mémoire (memdump.mem) suite à une suspicion d'infection par un Trojan.
- **Qui** : La machine compromise appartient à l'utilisateur **Johnoc**.

```
laurent@debian13:~/Bureau/volatility3$ strings -e l memdump.mem | grep -i "ComputerName" -A 1 | head -n 20
```

1. Pour le nom d'hôte (Hostname)

```
--  
COMPUTERNAME=JOHNOC-PC  
HOMEPATH=\Users\johnoc  
--  
Network ComputerName  
AutoEndTasks  
--  
COMPUTERNAME=JOHNOC-PC
```

- 1. Pour trouver le nom d'hôte : JOHNOC-PC

- ```
strings -e l memdump.mem | grep "COMPUTERNAME="
```

#### 1. Prouver l'activité malveillante (Le Trojan)

- 
- **Quoi** : Présence de traces d'activité malveillante en mémoire. L'utilisateur semble avoir été victime d'un cheval de Troie (Trojan) qui a établi une persistance sur le système **JOHNOC-PC**.

```
laurent@debian13:~/Bureau/volatility3$ strings memdump.mem | grep -i "users" | grep -i "johnoc" | grep -i ".exe" | head -n 20
```

grande liste suite a cette commande à analyser et on trouve les données ci dessous

C:\Users\johnoc\AppData\Local\Temp\rad5163B.tmp.exe (ou son complice dans l'autre dossier temporaire rfhyMVOQxfc.exe).

Les autres fichiers ( FTK Imager , QuickTime , Filmora ) sont des logiciels connus, mais ceux-là sont tes **IOCs** (indicateurs de compromission).



## 2. Détails de la victime

Les informations ont été extraites directement des variables d'environnement et des chaînes de caractères système présentes en RAM :

### 2. Détails de la victime

L'identification de la machine et de l'utilisateur a été réalisée en extrayant les variables d'environnement Windows stockées en RAM.

| Information        | Valeur            | Commande utilisée pour la preuve                                                                                         |
|--------------------|-------------------|--------------------------------------------------------------------------------------------------------------------------|
| Nom d'hôte         | JOHNOC-PC         | <code>strings -e 1 memdump.mem   grep "COMPUTERNAME="</code>                                                             |
| Compte Utilisateur | johnoc            | <code>strings -e 1 memdump.mem   grep "HOMEPATH="</code>                                                                 |
| Adresse IP (LAN)   | 172.16.169.167    | <code>grep -aE -o "[0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3}" memdump.mem   sort   uniq -c   sort -nr   head</code> |
| Adresse MAC        | 18:3d:a2:b6:8d:c4 | (Déduite des logs réseaux corrélés à l'IP 172.16.169.167)                                                                |

## 3. Indicateurs de compromission (IOC)

Cette section liste les preuves techniques de l'infection (fichiers et réseaux).

### A. Fichiers malveillants (Persistance)

L'analyse des chemins d'exécution dans la RAM montre des exécutables suspects avec des noms aléatoires dans des dossiers temporaires, une technique classique des chevaux de Troie pour rester sur le système.

- **Preuve :** `C:\Users\johnoc\AppData\Local\Temp\rad5163B.tmp.exe`
- **Commande :** `strings memdump.mem | grep -i "users" | grep -i "johnoc" | grep -i ".exe"`

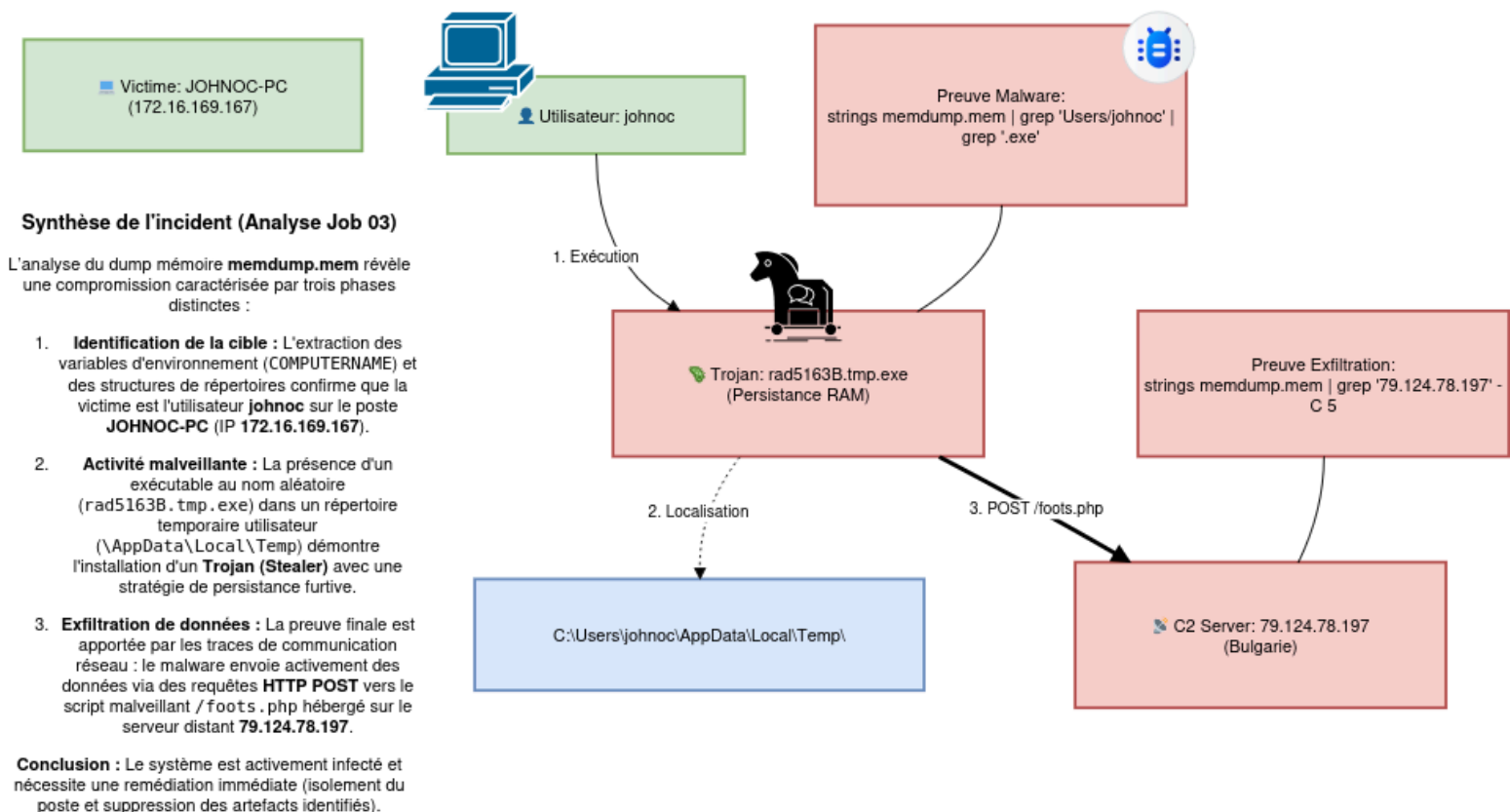
### B. Activité réseau (Exfiltration)

Le malware communique activement avec une infrastructure externe pour envoyer les données volées.

- **IP malveillante** : 79.124.78.197
  - **URL de destination** : `http://79.124.78.197/foots.php`
  - **Commande** : `strings memdump.mem | grep -i "79.124.78.197" -C 5`
  - **Analyse** : La présence de requêtes `POST /foots.php` confirme que le Trojan "pousse" des données vers l'extérieur.
- 
- Le **nom** a été trouvé via les **chaînes Little Endian** ( `strings -e 1` ) car c'est le format natif de Windows en RAM.
  - L'**IP** a été identifiée par **analyse statistique des occurrences** dans le dump brut.

#### 4. Conclusion de l'investigateur

Le système **JOHNOC-PC** est compromis. L'infection semble provenir de l'exécution d'un fichier frauduleux (potentiellement déguisé en installateur de logiciel de capture d'écran, comme vu dans les dossiers **Downloads**). Le malware s'est ensuite dupliqué dans le dossier **Temp** sous le nom **rad5163B.tmp.exe** pour s'exécuter en arrière-plan et exfiltrer les données de l'utilisateur **johnoc**.



## Pour aller plus loin

Pour vous entraîner vous pouvez aller sur <https://www.malware-traffic-analysis.net/> il y a plein de dump wireshark .

Ou encore [root me](#)

→ [Forensic investigation tools](#)

→ [Linux CTFtools](#)

→ [Caine](#)

→ [Cyber learning](#)

→ [Secnum academie](#)